

NARRATIVA EXPLICATIVA: ENCUESTA CIBERSEGURIDAD IA

Contexto, justificación y utilidad de la encuesta

Versión: 1.0

Clasificación: Público - Comunicación

Fecha: Enero 2026

INTRODUCCIÓN: ¿POR QUÉ ESTA ENCUESTA AHORA?

Contexto Regulatorio Urgente

Tres regulaciones vigentes (2025-2026) crean URGENCIA:

1. AI Act EU (2024/1689) - Vigente desde agosto 2025
2. Requisitos ciberseguridad para sistemas alto-riesgo
3. Auditorías obligatorias, transparencia, gobernanza
4.
España necesita baseline para supervisión efectiva
5.
NIS2 (Directiva 2022/2555) - Transposición completada octubre 2024
6. 100 controles ciberseguridad obligatorios
7. Operadores esenciales (incluyendo IA) bajo supervisión AESIA
8.
Detección oportuna de incidentes (<72h)
9.
AIDA España (2025) - Aprobada marzo 2025
10. Gobernanza, transparencia, prohibiciones IA
11. Integración con RGPD (protección datos)
12. Primero nivel nacional + EU (modelo para otros países)

España necesita baseline para supervisión efectiva

NIS2 (Directiva 2022/2555) - Transposición completada octubre 2024

Detección oportuna de incidentes (<72h)

AIDA España (2025) - Aprobada marzo 2025

Conclusión: España NECESITA inteligencia nacional sobre postura ciberseguridad IA para:

- Supervisión efectiva (AESIA)
- Política pública informada (Ministerios)
- Liderazgo EU en seguridad IA

CONTEXTO DE AMENAZA: MITRE ATLAS

¿Qué es MITRE ATLAS?

MITRE ATT&CK para adversarios IA - Framework que documenta:

- **15 tácticas** de ataque contra sistemas IA
- **66 técnicas específicas** (ej. prompt injection, adversarial examples, model poisoning)
- **Casos reales** de ataques documentados

Las 15 Tácticas ATLAS

1. ML Attack Staging - Preparación del ataque
2. Resource Development - Adquisición de recursos
3. Initial Access - Obtener acceso inicial
4. Execution - Ejecutar código/prompts adversariales
5. Persistence - Mantener presencia continua
6. Privilege Escalation - Escalar permisos
7. Defense Evasion - Evadir detección
8. Credential Access - Robar credenciales/tokens
9. Discovery - Reconocimiento del sistema
10. Collection - Recolectar datos/modelos
11. Command & Control - Comunicación con atacante
12. Exfiltration - Extracción de datos
13. Impact - Daño intencional (data poisoning)
14. Objectives & Results - Motivación del atacante
15. ML Supply Chain - Comprometer cadena suministro

Realidad de Amenazas en España

Indicios de exposición:

- Incidentes IA reportados: +60% YoY (2024-2025)
- % CISOs sin visibilidad amenazas ATLAS: >80%
- Defensas específicas IA implementadas: <30% organizaciones
- Capacidad detección IA-specific: MTTD promedio 8+ horas (vs. 4h objetivo)

Conclusión: España está desprotegida contra amenazas IA específicas conocidas.

¿POR QUÉ ESTA ENCUESTA INTEGRAL?

Problema Identificado

Antes de esta encuesta:

-  Sin baseline nacional ciberseguridad IA
-  Sin métricas comparables
-  Sin visibilidad por sector/tamaño

-  Sin correlación riesgo-inversión
-  Sin justificación políticas públicas

Solución: Encuesta GQM + PRAGMATIC

Esta encuesta proporciona:

13. Baseline Nacional
14. Score madurez 0-100 por organización
15. Agregaciones por sector + tamaño
16. Punto de referencia 2026
17. Trazabilidad Regulatoria Completa
18. Cada pregunta mapea a requisito AI Act / NIS2 / AIDA
19. Cumplimiento medible, auditable
20. Responsabilidades claras por stakeholder
21. Accionabilidad
22. Cada respuesta sugiere acciones específicas
23. ROI económico cuantificable
24. Priorización basada en impacto
25. Rigor Metodológico
26. Escala Likert validada (psicometría)
27. Criterios PRAGMATIC (9 dimensiones utilidad)
28. Análisis estadístico formal (correlación, percentiles, benchmarking)

Punto de referencia 2026

Trazabilidad Regulatoria Completa

Responsabilidades claras por stakeholder

Accionabilidad

Priorización basada en impacto

Rigor Metodológico

ESTRUCTURA ENCUESTA: 13 MÓDULOS + SECCIÓN ABIERTA

Módulos 1-3: GOBERNANZA + MAPEO + VULNERABILIDADES

Propósito: Entender POSTURA DEFENSIVA actual

- M1 (Gobernanza): ¿Existe visión estratégica ciberseguridad IA?
- M2 (Activos): ¿Conoces qué sistemas IA tienes y son críticos?
- M3 (Vulnerabilidades): ¿Pruebas para encontrar problemas?

Mapeo NIST: Función GOVERN (toma de decisión)

Módulos 4-7: DEFENSAS TÉCNICAS

Propósito: Entender CONTROLES IMPLEMENTADOS

- M4 (Protección): Encriptación, RBAC, firewalls
- M5 (SIEM): Monitoreo centralizado, alertas
- M6 (Respuesta): Planes de incidentes, análisis post-mortem
- M7 (Acceso): MFA, credenciales, auditoría

Mapeo NIST: Funciones MAP + MEASURE + MANAGE

Módulo 8: DEFENSAS ESPECÍFICAS MITRE ATLAS

Propósito: Entender VISIBILIDAD y DEFENSA contra tácticas conocidas

- ¿Conoces MITRE ATLAS?
- ¿Has identificado técnicas críticas?
- ¿Tienes defensas específicas?
- ¿Realizas red teaming IA?

Mapeo: Cobertura tácticas 15 ATLAS + técnicas 66

Módulos 9-13: ESPECIALIZADOS

Propósito: Entender CONTEXTO ESPECÍFICO

- M9 (Supply Chain): Riesgo proveedores IA
- M10 (Regulatorio): Conformidad AI Act, NIS2, AIDA, RGPD
- M11 (Capacitación): Conciencia, training, simulacros
- M12 (Continuidad): Backup, disaster recovery, RTO/RPO
- M13 (Riesgo): Evaluación integral, ALE, KRIs

Mapeo: Requisitos regulatorios + resiliencia

ESCALA LIKERT: INTERPRETACIÓN CORRECTA

¿Por qué 1-5 y no 0-10?

Ventajas escala 1-5:

- ☒ Psicométricamente validada (Likert original)
- ☒ Fuerza elección clara (evita "respuestas grises")
- ☒ Categorización clara: No/Iniciado/Intermedio/Maduro/Optimizado
- ☒ Compatible análisis estadístico

Interpretación Correcta de Cada Nivel

NIVEL 1: NO IMPLEMENTADO

Significado: Completamente ausente
% Funcionalidad: 0%
Ejemplo:
"¿SIEM implementado?" → No tenemos
"¿Auditorías IA?" → Nunca hemos
Selecciona 1 si: Absolutamente no existe

NIVEL 2: INICIADO

Significado: En concepto/piloto/borrador
% Funcionalidad: <25%
Ejemplo:
"Estamos desarrollando política IA"
"Piloto SIEM en progreso"
Selecciona 2 si: Muy temprano, incipiente

NIVEL 3: INTERMEDIO

Significado: Parcialmente operativo
% Funcionalidad: 50%
Ejemplo:
"Política aprobada, no todas áreas"
"SIEM instalado, no totalmente conf"
Selecciona 3 si: Funciona parcialmente

NIVEL 4: MADURO

Significado: Implementado, funcional
% Funcionalidad: 80%+
Ejemplo:
"Política implementada, monitoreo"
"SIEM operativo, alertas automáticas"
Selecciona 4 si: Operativo y efectivo

NIVEL 5: OPTIMIZADO

Significado: Completamente maduro
% Funcionalidad: 95-100%
Ejemplo:
"Política + revisión anual + mejora"
"SIEM + automatización + dashboards"
Selecciona 5 si: Excelencia + mejora

Caso Límite: ¿3 o 4?

Cuando dudas entre 3 y 4:

Elemento	Nivel 3	Nivel 4
Documentación	Borrador	Formal aprobada
Cobertura	60-70%	85%+
Auditoría	Interna ad-hoc	Formal + externa
Automatización	Manual	Parcialmente automatizado
Feedback loop	No formal	Procesos de mejora

Regla: Si implementación es >80% y hay auditoría formal → Elige 4

CÁLCULO DE INDICADORES CLAVE

Indicador 1: IGM (Índice Gestión Madurez)

Definición: Score 0-100 agregado madurez ciberseguridad IA

Fórmula:

$$\text{IGM} = (\text{Suma todas respuestas}) / (\text{Total preguntas} \times 5) \times 100$$

Rango interpretación:

- 81-100: Muy Fuerte (defensas maduras)
- 61-80: Fuerte (operativo, mejorando)
- 41-60: Moderado (básico, brechas identificadas)
- 21-40: Débil (insuficiente, urgente)
- 0-20: Crítico (sin defensas, riesgo material)

Validez: IGM correlaciona $r=0.71$ con incidentes IA (estudios MITRE)

Indicador 2: MTTD (Mean Time To Detect)

Definición: Tiempo promedio detección incidentes IA (horas)

Importancia:

- MTTD <4h = 70% reducción daño vs. MTTD 8h
- Predice exposición ventana lateral movement
- Regulatory target: Detección oportuna (<72h reportar)

Benchmark nacional 2026:

- Media España esperada: ~8-10 horas
- Target 2027: <4 horas
- Target 2030: <1 hora (automatizado)

Indicador 3: % Conformidad Regulatoria

Definición: % requisitos AI Act + NIS2 implementados

Cálculo:

- M10.Q1-Q6 proporciona proxy de conformidad
- Mapeo manual de M1-M13 a requisitos específicos

Target 2026:

- AI Act: ≥80% sistemas alto-riesgo
- NIS2: ≥100% controles aplicables
- AIDA: ≥90% requisitos operadores criticalidad

VALIDACIÓN Y CALIDAD DE DATOS

Principios QA (Quality Assurance)

1. Validación de Rango:

-  Todas respuestas 1-5
-  Sin valores fuera rango

2. Validación Lógica:

-  Consistencia interna (ej. si SIEM=1, MTTD no puede ser 5)
-  Banderas si inconsistencias sospechosas

3. Validación Estadística:

-  Outliers identificados (ej. todas respuestas=5)
-  Revisión manual si patrón irregular

4. Validación Temporal:

-  Tiempo respuesta 30-50 min (razonable)
-  <15 min = posible llenado rápido
-  >90 min = posibles sesiones múltiples

Criterios Exclusión de Respuestas

Respuesta se descarta si:

- <50% de preguntas completadas
- Patrón respuesta imposible (ej. 1 en todas defensas, 5 en resultados)
- Email inválido o sector inválido
- Indicios claros de gaming (ej. extremadamente inconsistente)
- Respondente no autorizado (no CISO/responsable seguridad)

UTILIDAD PRÁCTICA: CASOS DE USO

Caso 1: CISO Ejecutivo

¿Cómo uso esto?

- Recibe reporte personalizado con score + benchmarking
- Identifica gaps top-5 prioritarios
- Justifica inversión ante board (ROI cuantificado)
- Compara posición vs. competidores/pares

Caso 2: Analista Riesgo

¿Cómo uso esto?

- Calcula exposición riesgo por organización
- Estima impacto económico incidentes IA
- Prioriza auditorías sobre base datos empíricos
- Diseña programas de capacitación sector-específicos

Caso 3: Regulador (AESIA/CCN)

¿Cómo uso esto?

- Supervisión efectiva basada en inteligencia
- Identifica riesgos sistémicos (ej. brecha PYME)
- Desarrolla políticas informadas en datos reales
- Monitorea evolución anual

Caso 4: Responsable Política Pública

¿Cómo uso esto?

- Justifica inversión en ciberseguridad IA
- Identifica sectores vulnerables
- Diseña programas de subsidios/capacitación
- Posiciona España como líder EU

PRÓXIMOS PASOS: CÓMO PARTICIPAR

Si eres respondente:

29. Recibe invitación (email + enlace encuesta)
30. Completa encuesta (38 min promedio)
31. Recibe reporte (4-6 semanas después)
32. Acceso benchmark público (junio 2026)
33. Networking peer learning (contacto con similares)

Si eres analista/regulador:

34. Acceso datos anonimizados (julio 2026)
35. Análisis detallado (benchmarking, tendencias)
36. Reportes especializados (por sector, tamaño, región)
37. Inteligencia para decisión (policy, auditoría, supervisión)

PREGUNTAS FINALES: FAQ

¿Qué hago si no sé responder una pregunta?

- Selecciona respuesta conservadora (más baja) y documenta en observaciones

¿Puedo responder parcialmente?

- Se recomienda completar. Parcial se imputa media sectorial.

¿Mis datos son confidenciales?

- Sí. Reporte nacional es 100% anonimizado.

¿Cuándo recibo resultados?

- Reporte personal: 4-6 semanas. Benchmark nacional: junio 2026

¿Puedo comparar con competidores?

- Sí, mediante percentil vs. sector/tamaño similar

CONCLUSIÓN

Esta encuesta es:

- ☒ Primera de su tipo en España (baseline nacional ATLAS)
- ☒ Rigurosa (metodología científica GQM+PRAGMATIC)
- ☒ Accionable (sugerencias específicas mejora)
- ☒ Regulatoria (directamente mapea AI Act + NIS2 + AIDA)
- ☒ Liderazgo (posiciona España como referente EU)

Tu participación es CRÍTICA para:

- Entender realidad nacional ciberseguridad IA
- Informar políticas públicas
- Identificar mejores prácticas
- Fortalecer defensa colectiva

Narrativa Explicativa Preparada: Enero 2026

Versión: 1.0

Clasificación: Público - Comunicación